

Hybrid Post-Quantum Authentication from OPAQUE and ML-KEM-768: Construction, Formal Analysis, and a Reproducible Implementation

Oleksandr Melnychenko^a

^a*Khmelnytskyi National University, Khmelnytskyi, Ukraine*

Abstract

Password-authenticated key exchange remains a practical authentication mechanism, but classical OPAQUE relies on elliptic-curve hardness and has no native post-quantum contribution in the authentication transcript. This paper studies a narrower migration question: can an OPAQUE-like augmented PAKE be reinforced with ML-KEM-768 while preserving the three-message KE1–KE2–KE3 interaction profile and making the resulting syntax independently auditable?

We specify Hybrid PQ-OPAQUE, a concrete OPAQUE-derived construction in which four Ristretto255 Diffie–Hellman terms and one ML-KEM-768 shared secret are combined by HKDF under a transcript-dependent salt. The specification fixes the byte-level message layout, account-context binding through `acct`, deterministic derivation of the OPRF key from the service root secret σ_{oprf} , and inclusion of pk_{kem} and ct_{kem} in the authenticated transcript.

The evidence is deliberately scoped. ProVerif 2.05 models secrecy and authentication in separate symbolic models; Tamarin Prover 1.10.0 checks a surrogate 4DH model; and the Rust artifact exercises serialization, state-lifecycle, rejection, and benchmark paths. These results support a bounded design argument rather than a machine-checked proof of the implementation or a full computational proof of the hybrid combiner.

On the stated Linux/Xeon benchmark platform, the complete hybrid handshake occupies 2715 bytes, end-to-end authentication takes 836.11 ms, and the KSF-free post-quantum path adds 379.45 μs . The main performance constraint is Argon2id rather than ML-KEM, while the main operational boundary is separation of σ_{oprf} from passive authentication records.

Keywords: OPAQUE, PAKE, ML-KEM-768, post-quantum cryptography, hybrid key exchange, Ristretto255, HKDF, Tamarin, ProVerif, Rust

1. Introduction

1.1. Motivation

Password authentication remains widely deployed in contemporary distributed systems. Survey evidence indicates that more than 80% of authentication procedures in web applications and network services still rely on passwords [1, 2]. Password-authenticated key-exchange protocols (PAKEs) allow two parties sharing a low-entropy secret to establish a protected channel without revealing that secret to an adversary [3]. Among augmented PAKE constructions, OPAQUE [4] is a well studied scheme: under compromise of the authentication database alone, the server stores a cryptographic record rather than a password equivalent [5]. In deployed systems, this property depends on a clear trust boundary, because compromise of the global secret from which OPRF keys are derived is distinct from compromise of a passive record store.

This reliance on classical hardness assumptions is a concern in the presence of quantum adversaries. Shor’s algorithm [6] applies to cryptosystems based on the discrete logarithm problem, including elliptic-curve key exchange and PAKE constructions built on related assumptions [7]. Earlier estimates suggested that breaking Ristretto255/Curve25519 would require a cryptographically relevant quantum computer with approximately 2,330 logical qubits [8]. More recent work reports two resource profiles for Shor’s algorithm against 256-bit ECDLP over the `secp256k1` curve: no more than 1200 logical qubits with 90 million Toffoli operations, or no more than 1450 logical qubits with 70 million Toffoli operations [9]. These figures are not parameter-specific estimates for Ristretto255. They are used here only as a contemporary calibration point for 256-bit elliptic-curve migration risk. The store-now-decrypt-later strategy [10], in which an adversary archives encrypted traffic for future decryption, adds to that motivation for systems protecting long-lived confidential data.

In August 2024, NIST published the first post-quantum cryptography standards, including FIPS 203 for ML-KEM [11] and FIPS 204 for ML-DSA [12]. Hybrid constructions that combine classical and post-quantum components are being introduced in TLS 1.3 [13], Signal (PQXDH) [14], and

WireGuard [15]. Password authentication has not reached the same level of standardization. Classical OPAQUE in its current IETF specification [5] contains no mechanism aimed at quantum attacks, and other established PAKE protocols such as SRP and SPAKE2 have the same limitation. Recent work on post-quantum and hybrid PAKE has produced compact KEM-based constructions [16], UC/QROM-secure schemes [17], and formal studies of hybrid composition [18, 19]. What remains less developed is the combination of an augmented-PAKE design with explicit message syntax, scoped formal claims, measurements, and implementation-level evidence.

The concrete instantiation is anchored in final standards where such standards exist: ML-KEM-768 follows FIPS 203 [11], OPAQUE is compared against RFC 9807 [5], Ristretto255 follows RFC 9496 [26], and HKDF follows RFC 5869 [31]. Argon2id [30] is used as the password-hardening baseline, and Criterion [34] is used only as the measurement framework for the Rust artifact.

A secondary application motivation is audit-heavy cyber-physical authentication, where login events may be part of telemetry, inspection, and operational-control workflows rather than isolated web sessions [35, 36, 37]. These works motivate stable protocol records and explicit failure semantics, but they are not evidence for the cryptographic security of Hybrid PQ-OPAQUE.

1.2. Research Scope and Evaluation Objective

This paper studies a narrower engineering question: whether OPAQUE can be reinforced with ML-KEM-768 while preserving its three-message authentication flow. The construction combines four Ristretto255 Diffie–Hellman values with an ML-KEM-768 shared secret, fixes wire-format versioning, binds an explicit account context represented by the account identifier `acct` into the transcript, and evaluates the result using symbolic analysis and an executable reference implementation in Rust. The contribution is not a general theory of hybrid PAKE composition; it is an implementation-level augmented-PAKE design with explicit syntax, stated assumptions, and a deliberately limited claim set.

The evaluative objective is to determine whether this migration profile can be specified, modeled, implemented, and measured without silently changing the OPAQUE interaction profile or the augmented-PAKE trust boundary. The paper therefore keeps each claim tied to a corresponding evidence layer, as summarized in Table 1. In this paper, the research artifact denotes the

accompanying source package that keeps these evidence layers aligned: Rust crates, formal models, archived verification logs, tests, benchmark harnesses, and adapter documentation.

Table 1: Evaluation objective and evidence layers used in the manuscript

Question	Evidence used	Boundary
Can ML-KEM be added without an extra message?	KE1–KE2–KE3 syntax, wire-size accounting, and serializer tests	This is an OPAQUE-like migration profile, not a claim of full RFC 9807 conformance.
Is the post-quantum material transcript-bound?	Account context, extended transcript equations, MAC confirmation, and mutation tests	The combiner argument is scoped to the stated extractor interpretation.
What formal evidence supports the design?	Split ProVerif models and a surrogate Tamarin 4DH model	Symbolic evidence does not machine-check the Rust implementation or side-channel behavior.
What is the measured cost?	Criterion benchmarks on the stated Linux/Xeon platform	Timings are platform-specific and require recalibration on mobile, browser, and embedded targets.

1.3. Research Contributions

1. **A concrete OPAQUE migration profile.** The paper specifies a three-message OPAQUE-derived construction that combines four Ristretto255 DH terms with an ML-KEM-768 shared secret, fixes wire-format versioning, and binds account context, pk_{kem} , and ct_{kem} into the authenticated transcript.
2. **A scoped evidence package.** The manuscript aligns reduction sketches, two ProVerif models, a surrogate Tamarin 4DH model, and executable conformance tests to the same claim boundary, while explicitly separating symbolic evidence from implementation proof.
3. **A reproducible cost and trust-boundary analysis.** The artifact reports message expansion, Criterion benchmarks, and operational assumptions for σ_{prf} , showing that the dominant latency comes from Argon2id while the main new overhead is wire-format expansion.

The remainder of the paper follows a claim-evidence structure. Section 2 positions the construction against OPAQUE, post-quantum PAKE, and hybrid-composition work. Section 3 states the objective, roles, assets, and threat boundary. Section 4 specifies the protocol syntax and key schedule. Section 5 states the symbolic security interpretation and its limits. Section 6 reports measurements and then separates implementation diagnostics from the main results.

1.4. Terminology

Table 2 fixes the small vocabulary needed before the protocol is defined. In particular, the distinction between payload and wire format, and the role of `acct` as cryptographic context, are used throughout the construction.

Table 2: Terminology used in the paper	
Term	Meaning in this paper
Wire format	The complete byte-level representation of a message on the channel, including the version prefix and protocol service fields
Payload	The message body excluding the version prefix and any external wrappers
Account identifier (<code>acct</code>)	A stable byte string identifying the user’s account; in this construction it is cryptographic context, not only a database lookup key
Initiator $\mathcal{C}$	The party that holds the password, creates KE1, verifies KE2, and sends KE3
Record-holding responder $\mathcal{S}$	The augmented-PAKE party that stores the registration record, evaluates the OPRF, creates KE2, and verifies KE3
Augmented PAKE (aPAKE)	A class of password-authenticated key-exchange protocols in which the server stores a verifier rather than the password itself or its direct equivalent
Key-derivation scheme	The sequence of extraction and expansion procedures that produces session and auxiliary keys
Research artifact	Source code, formal models, tests, and benchmarks needed for independent reproduction of the reported results

In addition, the formal exposition uses `acct` for the account identifier and σ_{oprf} for the root secret from which server-side OPRF keys are derived. Literal ASCII domain-separation strings are replaced below with the symbols L_{oprf} , L_{seed} , L_{key} , L_{ksf} , L_{salt} , L_{ctx} , L_{τ} , and L_{comb} ; for the purposes of formal analysis, their stability and mutual distinctness matter, whereas the concrete textual representation of the implementation string does not. For byte strings, $\text{Trunc}_n(X)$ denotes the leftmost n octets of X . Advantage expressions in the manuscript are scoped labels for the argument being made, not theorem-level security definitions for an independent PAKE family. When a bound is written below, it should be read under the stated compromise model, primitive assumptions, and modeling abstractions of that subsection.

2. Related Work and Existing Solutions

This section distinguishes source status because post-quantum standardization is still moving. Final standards and RFCs, including FIPS 203 and RFC 9807, are treated as normative anchors; peer-reviewed papers are used for established PAKE and post-quantum results; ePrints and Internet-Drafts are used as current but provisional evidence; and technical white papers are used only for contextual calibration.

2.1. Password-Authenticated Key-Exchange Protocols

Password-authenticated key exchange (PAKE) refers to a class of protocols that enables two parties sharing a low-entropy secret (a password) to establish an authenticated session key resistant to offline dictionary attacks [20]. PAKE protocols are commonly divided into two categories:

- *Balanced PAKE*, in which both parties store equivalent password-derived representations. Representative examples are EKE [21], SPAKE2 [22], and CPace/AuCPace [23].
- *Augmented PAKE (aPAKE)*, in which the server stores only a verifier rather than the password or its direct equivalent. Representative examples are SRP [24], AuCPace [23], and OPAQUE [4].

Table 3: Comparative characteristics of selected PAKE protocols

Property	EKE	SRP	SPAKE2	OPAQUE
Type	Balanced	Augmented	Balanced	Augmented
Non-equivalent server record	No	Partial	No	Yes
Pre-computation resistance	No	No	No	Yes
Forward secrecy	Yes	Yes	Yes	Yes
Resistance to server-record compromise	No	Partial	No	In the passive-database model
Formal security proof	Ideal-cipher model	None	ROM	UC
Quantum resistance	No	No	No	No

In Table 3, the OPAQUE entry regarding server storage compromise should be read in the narrow but standard sense of compromise of the authentication-record database alone. It does not cover compromise of a global server secret from which OPRF keys may be derived.

2.2. OPAQUE: A Formal Overview

OPAQUE [4] consists of a registration phase and an authentication phase, both built around an oblivious pseudorandom function (OPRF). Standard IETF OPAQUE uses triple Diffie–Hellman (3DH): $dh_1 = sk_S \cdot PK_C$ (mutual authentication), $dh_2 = sk_S \cdot E_C$, $dh_3 = e_S \cdot PK_C$ (forward secrecy). The construction analyzed here adds a fourth Diffie–Hellman term, $dh_4 = e_S \cdot E_C$. This term binds the two ephemeral components within a single transcript and, at the level of 4DH intuition, is intended to complicate UKS-like substitutions; here it is treated as a design rationale rather than as an independently proved property. In this paper, “4DH” denotes these four Diffie–Hellman terms in the key schedule, not a fourth authentication message; the message flow remains KE1–KE2–KE3. Baseline OPAQUE has been proved in the Universal Composability (UC) model [25].

Oblivious pseudorandom function (OPRF). The OPRF core uses a hash-to-group map into Ristretto255 [26]:

$$\begin{aligned}\alpha &= r \cdot H'(\text{ctx} \parallel x), \\ \beta &= k \cdot \alpha, \\ F_k(x) &= r^{-1} \cdot \beta,\end{aligned}\tag{1}$$

where $r \xleftarrow{\$} \mathbb{Z}_q^*$ is a random initiator-side blinding scalar, k is the responder’s OPRF key, and ctx is the domain-separation context for the invocation.

2.3. Post-Quantum Cryptography and the NIST 2024 Standards

ML-KEM-768 is selected at NIST security level 3 (roughly aligned with AES-192). Its parameters are $|pk| = 1184$ bytes, $|ct| = 1088$ bytes, and $|ss| = 32$ bytes under IND-CCA2 security. The abstraction is

$$\text{KeyGen}() \rightarrow (pk, sk); \quad \text{Encaps}(pk) \rightarrow (ct, ss); \quad \text{Decaps}(sk, ct) \rightarrow ss. \tag{2}$$

2.4. Rationale for Selecting ML-KEM-768

The selection of ML-KEM-768 follows from the deployment constraints of interactive password authentication. ML-KEM-512 offers smaller messages and lower overhead, but it targets NIST level 1. ML-KEM-1024 provides a higher nominal security level, but it also increases message size and transport cost. For interactive password authentication, where the protocol already includes a comparatively expensive KSF, the relevant design criterion is the balance among cryptographic strength, message size, and deployability.

ML-KEM-768 provides a middle operating point in that trade-off space. Within the ML-KEM family it aligns NIST level 3 with the long-term protection of account credentials and session secrets while avoiding the larger transport burden imposed by ML-KEM-1024. Although pk_{kem} and ct_{kem} enlarge messages relative to classical OPAQUE, they do not render the protocol unsuitable for interactive use.

2.5. Design Alternatives Considered

Several hybridization strategies are possible, and they lead to different operational trade-offs. A purely transport-layer migration, for example, can use a post-quantum or hybrid TLS key exchange while leaving the application authentication protocol unchanged. That path is attractive for deployment, but it does not make the password-authentication transcript itself hybrid. Conversely, replacing the OPRF with a post-quantum OPRF would address the password-randomization layer more directly, but efficient and standardized post-quantum OPRFs are less mature than ML-KEM-based key establishment. A third option is to store long-lived post-quantum material in the registration record. This would increase migration pressure on account state and would enlarge the server-side record that operators must protect.

The construction studied here therefore adopts a narrower design: keep the OPRF and envelope structure close to OPAQUE, add ML-KEM-768 only in the ephemeral authentication path, and bind the resulting public KEM values into the same transcript that authenticates the classical exchange. This choice does not address every post-quantum PAKE problem, but it gives a concrete migration point whose wire format, implementation cost, and trust boundary can be measured. Table 4 records the alternatives considered and the reason for selecting the ephemeral ML-KEM path.

2.6. Recent Approaches to Post-Quantum PAKE (2023–2026)

Between 2023 and 2026, several research lines became relevant to post-quantum PAKE and hybrid aPAKE design.

KEM-based schemes indicate that compact lattice-based PAKE is feasible. A representative example is CHIC [16], which combines a compact construction with a UC-security argument and implementation-level evaluation. In parallel, UC- and QROM-oriented results such as [17] strengthen compositional guarantees for the post-quantum setting. These results are important, but they do not directly resolve the migration problem for deployed OPAQUE-like systems, where asymmetric initiator–responder roles,

Table 4: Hybridization strategies and their implications for this work

Strategy	Benefit	Limitation for the present objective
Hybrid transport only	Minimal application changes when the surrounding channel already supports post-quantum key exchange	The PAKE transcript and application-level authentication state remain classical.
Post-quantum OPRF replacement	Targets the password-randomization layer directly	Efficient post-quantum OPRF choices are less standardized and would change the registration and envelope design more deeply.
Persistent PQ material in the record	Can attach post-quantum state to the account itself	Enlarges long-lived account records and complicates staged migration.
Separate PAKE and KEM composition	Keeps the classical PAKE largely unchanged	Requires a separate composition argument and careful binding to avoid treating two independent handshakes as one authenticated exchange.
Ephemeral ML-KEM in the OPAQUE transcript	Preserves three messages, keeps PQ material out of the registration record, and exposes concrete wire-format costs	Leaves the OPRF layer classical and requires a carefully scoped hybrid-combiner interpretation.

wire-format stability, and compatibility with existing authentication workflows are central.

A second line of work considers replacement of classical OPRF components and the compilation of KEM primitives into PAKE. Lattice-based post-quantum OPRF constructions remain more communication-intensive than elliptic-curve instantiations [27], and generalized KEM-to-PAKE approaches require careful treatment of ideal-cipher assumptions, hashing into public-key spaces, and low-entropy secrets [16]. By contrast, isogeny-based approaches have lost practical relevance after the Castryck–Decru attacks on SIDH-derived constructions [28].

Recent work also treats hybridization itself as a distinct design problem. PAKE combiners [18] and UC analyses of hybrid PAKE [19] primarily address proof structure and composition, while the CFRG-related hybrid PAKE draft [29] indicates active standardization interest. The present work is narrower: it is not a new UC-secure PAKE family and not a general combiner theorem. Its novelty is an OPAQUE migration profile with explicit transcript syntax, no additional authentication message, no persistent post-quantum account state, a stated σ_{oprf} trust boundary, and reproducible implementation measurements.

Compared with CHIC and UC/QROM-oriented post-quantum PAKEs, the construction prioritizes migration from an augmented OPAQUE setting rather than a clean-slate PAKE design. Compared with PAKE-combiner

work, it provides concrete wire syntax and artifact evidence rather than a general composition proof. Compared with transport-only hybridization, it binds the post-quantum contribution inside the password-authentication transcript itself.

3. Problem Statement

3.1. Problem Formulation and Threat Model

Let $\mathcal{C}$ be the *initiator* and $\mathcal{S}$ be the *record-holding responder*. The initiator holds the password pwd and completes OPRF finalization locally. The responder stores the registration record rec and derives account-specific OPRF keys from σ_{oprf} . This vocabulary is used throughout the threat model, figures, symbolic models, and implementation discussion; deployment terms such as client and server are treated only as explanatory aliases. Let $\mathbb{G}$ denote the prime-order Ristretto255 group of order q with generator g .

Assets to be protected:

- the password pwd ; the static keys sk_C, sk_S ; the ephemeral keys $e_C, e_S, sk_{\text{kem}}$;
- the registration record $\text{rec} = (\text{envelope}, pk_C)$;
- the session key K_s , the master key K_m , and the shared secret ss_{kem} .

Adversarial model. Three adversarial classes are considered:

- *Classical adversary* $\mathcal{A}_C$: a probabilistic polynomial-time active man-in-the-middle capable of compromising server-side storage;
- *Quantum adversary* $\mathcal{A}_Q$: an adversary modeled as capable of solving DLP/ECDLP via Shor’s algorithm and pursuing a “harvest now, decrypt later” strategy;
- *Composite adversary* $\mathcal{A}_{CQ}$: an active man-in-the-middle equipped with a quantum computational oracle.

Threat-model boundary. The adversary controls the network and may record, replay, delay, drop, and modify protocol messages. The database-compromise scenario gives the adversary the registration record and associated public metadata, but not the operational secret σ_{oprf} from which

account-specific OPRF keys are derived. The model also permits post-session compromise of long-term static protocol keys when discussing forward secrecy. It does not include full endpoint compromise during an active session, malicious random number generation, password-reset workflows, resource-exhaustion denial-of-service analysis, or microarchitectural side channels. These excluded cases are operationally important, but they require different mechanisms from the protocol-level construction studied here.

Operationally, the database-only claim requires $\sigma_{\text{opr}}f$ to be managed outside the password-record store and outside ordinary database backup, analytics, and logging paths. A conforming deployment should keep $\sigma_{\text{opr}}f$ in a KMS, HSM, or equivalent secret-management boundary; limit derivation access to the authentication service; exclude plaintext $\sigma_{\text{opr}}f$ from snapshots, crash dumps, and support bundles; audit derivation calls; and define an incident procedure in which suspected $\sigma_{\text{opr}}f$ exposure is treated as verifier compromise, requiring root rotation, account re-enrolment or password reset, and temporary rate tightening. Table 5 makes this boundary explicit for the main claims.

Table 5: Threat-model boundary used for the main security claims

Scenario	Included in the claim	Boundary
Active network attack	Full Dolev–Yao control of messages and transcript manipulation	Does not model traffic analysis or availability attacks.
Database disclosure	Registration record, stored public keys, and protocol metadata may be exposed	Offline resistance assumes $\sigma_{\text{opr}}f$ remains outside the compromised store.
Post-session key exposure	Long-term static keys may be compromised after completion	Session-local ephemerals and ML-KEM decapsulation state are assumed destroyed.
Quantum attack on classical DH	Classical DH terms may be treated as recoverable in the long-term migration argument	The post-quantum layer is then relied upon under the ML-KEM assumption.
Implementation behavior	Serialization, state lifecycle, version handling, and external-adapter errors are checked by tests	Tests do not establish absence of side channels or memory-safety bugs in external crates.

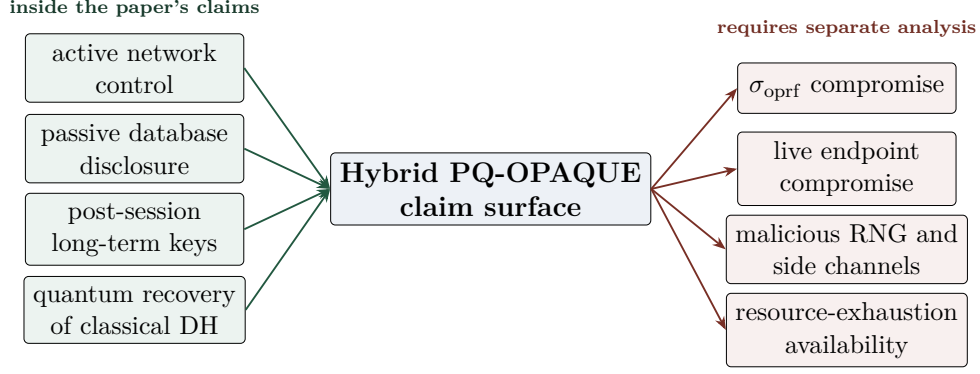


Figure 1: Threat-boundary map for the main claims. The construction is analyzed against active network control, database disclosure, post-session long-term key exposure, and later quantum recovery of classical DH terms. Compromise of the OPRF root secret, live endpoint compromise, malicious randomness, side channels, and availability attacks are outside the claim surface.

Protocol requirements:

- R1** (OPAQUE-derived goals): password secrecy, forward secrecy, mutual authentication, and resistance to offline guessing;
- R2** (Post-quantum reinforcement): inclusion of a KEM-based contribution against “harvest now, decrypt later” exposure;
- R3** (Hybrid-source interpretation): the key-material combiner should support a stated extractor-based reading in the adopted model, so that the paper can identify precisely which source assumptions remain necessary for final-key recovery;
- R4** (Interaction preservation): preservation of three protocol messages and 1.5 network round trips;
- R5** (Implementability): a reproducible reference implementation in Rust suitable for further analysis and engineering.

3.2. Formal Definitions

Definition 3.1 (KEM). (KeyGen, Encaps, Decaps): $\text{KeyGen}() \rightarrow (pk, sk)$; $\text{Encaps}(pk) \rightarrow (ct, ss)$; $\text{Decaps}(sk, ct) \rightarrow ss$. *IND-CCA2 security means that no polynomial-time adversary equipped with a decapsulation oracle can distinguish the real ss from a random string.*

Definition 3.2 (Hybrid aPAKE in the sense of this paper). *Protocol Π between $\mathcal{C}(\text{pwd})$ and $\mathcal{S}(\text{rec})$, in which*

$$\begin{aligned} \text{IKM}_{\text{cl}} &= \text{Encode}(dh_1) \parallel \text{Encode}(dh_2) \\ &\quad \parallel \text{Encode}(dh_3) \parallel \text{Encode}(dh_4), \\ \text{IKM}_{\text{pq}} &= ss_{\text{kem}}, \end{aligned}$$

and the final pre-key is formed as

$$\text{PRK} = \text{HKDF-Extract}(\text{salt}_\tau, \text{IKM}_{\text{cl}} \parallel \text{IKM}_{\text{pq}}).$$

The subsequent analysis examines the extent to which such a construction is compatible with the hybrid-source interpretation used within the threat model considered here.

Definition 3.3 (Pseudorandomness of HKDF-Extract). *HKDF-Extract based on HMAC-SHA-512 is modeled as an extractor: if IKM contains hidden computational entropy relative to the adversary, then the output PRK is computationally indistinguishable from uniform up to advantage at most ε .*

Notation: $\mathbb{G}$ denotes Ristretto255 with $|\mathbb{G}| = q$; lowercase letters denote scalars; uppercase letters denote curve points; $\parallel$ denotes concatenation; $H(\cdot)$ denotes SHA-512; and $\mathcal{K} = (K_s, K_m)$ denotes the session and master keys.

4. The Proposed Hybrid PQ-OPAQUE Protocol

4.1. Architecture and Overview

Hybrid PQ-OPAQUE is a hybrid post-quantum extension of OPAQUE [5]. The protocol preserves the augmented-PAKE asymmetry: in an honest execution, the password is neither transmitted to nor reconstructed by the record-holding responder. Authentication remains a three-message KE1–KE2–KE3 exchange. The only post-quantum state added to authentication is ephemeral ML-KEM-768 material: pk_{kem} in KE1 and ct_{kem} in KE2. Figure 2 shows where these values, together with the account-context hash η , enter the transcript and key schedule.

Table 6 fixes the concrete primitive choices used by the construction and by the implementation evaluated below.

The authentication-message sizes in Table 7 separate payload size from wire-format size; the latter includes the one-byte protocol version prefix.

Figure 3 shows that the post-quantum layer leaves finalization almost unchanged while increasing the transport budget of the first two messages, namely the phases that carry pk_{kem} and ct_{kem} .

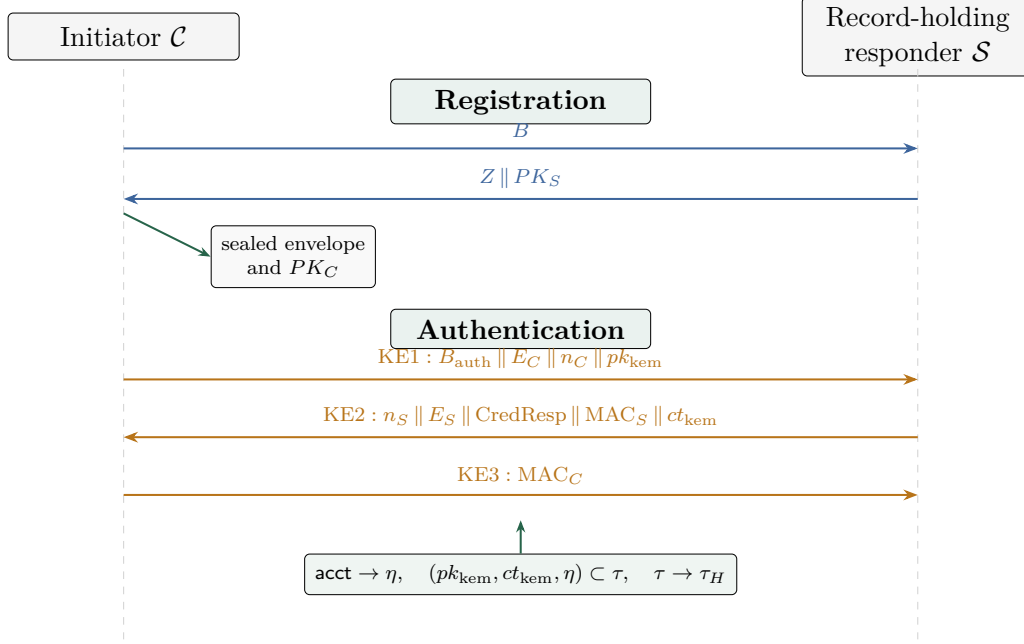


Figure 2: Hybrid PQ-OPAQUE message flow between initiator $\mathcal{C}$ and record-holding responder $\mathcal{S}$. ML-KEM public and ciphertext material are carried in KE1 and KE2, while account and transcript binding feed the authenticated key schedule without adding an authentication message.

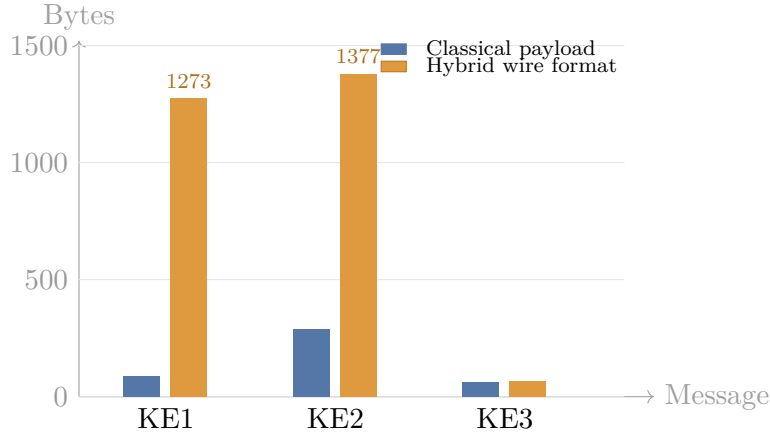


Figure 3: Comparison of authentication-message sizes: the additional wire-format overhead is concentrated in KE1 and KE2, whereas KE3 remains essentially unchanged.

Table 6: Cryptographic primitives used in Hybrid PQ-OPAQUE

Component	Primitive	Implementation	Security level
OPRF group	Ristretto255	curve25519-dalek	128 bits
Hash function	SHA-512	sha2	256 bits
KDF (extract)	HKDF-Extract (HMAC-SHA-512)	hmac + sha2	256 bits
KDF (expand)	HKDF-Expand (HMAC-SHA-512)	hmac + sha2	256 bits
MAC	HMAC-SHA-512	hmac + sha2	256 bits
KSF	Argon2id (MODERATE)	argon2	Adaptive
AEAD	XSalsa20-Poly1305	crypto_secretbox	256 bits
KEM	ML-KEM-768 (FIPS 203)	ml-kem	NIST Level 3
Classical exchange	4DH (Ristretto255)	curve25519-dalek	128 bits
Constant-time comparison	Bytewise without early exit	subtle	—

Table 7: Authentication-message sizes in payload and wire format

Message	Classical payload	Hybrid payload	Hybrid wire format	Post-quantum overhead
KE1	88 bytes	1272 bytes	1273 bytes	+1184 (pk_{kem})
KE2	288 bytes	1376 bytes	1377 bytes	+1088 (ct_{kem})
KE3	64 bytes	64 bytes	65 bytes	0
Total	440 bytes	2712 bytes	2715 bytes	+2272 (+516%)

4.2. Normative Wire Format and Rejection Rules

All authentication messages are fixed-width byte strings. The first byte is the protocol version $v = 0x01$. KE1, KE2, and KE3 contain no endian-sensitive integer fields; all components below are copied exactly as octet strings at fixed offsets. The account identifier `acct` is an external authenticated-context input, not a field inside these messages.

Table 8: Fixed authentication-message layout

Message	Offset range	Field	Length and validation rule
KE1	0	v	1 byte; must equal <code>0x01</code>
KE1	1–32	B_{auth}	32-byte blinded OPRF group element; canonical Ristretto encoding required
KE1	33–64	E_C	32-byte initiator ephemeral Ristretto public key
KE1	65–88	n_C	24-byte initiator nonce
KE1	89–1272	pk_{kem}	1184-byte ML-KEM-768 public key
KE2	0	v	1 byte; must equal <code>0x01</code>
KE2	1–24	n_S	24-byte responder nonce
KE2	25–56	E_S	32-byte responder ephemeral Ristretto public key
KE2	57–224	CredResp	168-byte credential response
KE2	225–288	MAC_S	64-byte HMAC-SHA-512 confirmation token
KE2	289–1376	ct_{kem}	1088-byte ML-KEM-768 ciphertext
KE3	0	v	1 byte; must equal <code>0x01</code>
KE3	1–64	MAC_C	64-byte HMAC-SHA-512 confirmation token

Parsing is fail-closed. Exact length is required before field interpretation. Unsupported version is distinguished from malformed length at the public API boundary, while MAC, envelope, and password failures are collapsed into authentication failure to reduce account and stage fingerprinting. Ristretto encodings must decompress canonically; ML-KEM public keys and ciphertexts must have the FIPS 203 lengths shown in Table 8; malformed public inputs are rejected rather than silently normalized.

4.3. Registration Phase

Step 1 ($\mathcal{C} \rightarrow \mathcal{S}$). Generation of the static pair (sk_C, PK_C) followed by OPRF blinding:

$$r \xleftarrow{\$} \mathbb{Z}_q^*, \quad B = r \cdot H'(L_{\text{opr}} || 0x00 || \text{pwd}). \quad (3)$$

RegistrationRequest = B (32 bytes).

Step 2 ($\mathcal{S} \rightarrow \mathcal{C}$). Derivation of the OPRF key:

$$s_{\text{oprf}} = \text{Trunc}_{32}(\text{HMAC}(\sigma_{\text{oprf}}, L_{\text{seed}})), \quad (4)$$

$$k_{\text{oprf}} = \text{ScalarReduce}(\text{HMAC}(s_{\text{oprf}}, L_{\text{key}} \parallel \text{acct} \parallel \text{ctr})), \quad (5)$$

where ctr is the smallest one-byte counter for which the resulting scalar is non-zero. The responder computes $Z = k_{\text{oprf}} \cdot B$; the key k_{oprf} is then immediately destroyed. The response is $Z \parallel PK_S$ (64 bytes).

Step 3 ($\mathcal{C}$). OPRF unblinding:

$$U = r^{-1} \cdot Z.$$

OPRF output:

$$y_{\text{oprf}} = H(L_{\text{oprf}} \parallel 0\text{x}01 \parallel \text{pwd} \parallel U). \quad (6)$$

KSF input and salt:

$$x_{\text{ksf}} = H(L_{\text{ksf}} \parallel y_{\text{oprf}} \parallel \text{pwd}), \quad (7)$$

$$\text{salt}_{\text{ksf}} = \text{Trunc}_{16}(H(L_{\text{salt}} \parallel y_{\text{oprf}})). \quad (8)$$

The randomized password is then computed with Argon2id [30] as

$$\text{rwd} = \text{Argon2id}(x_{\text{ksf}}, \text{salt}_{\text{ksf}}; m = 256 \text{ MiB}, t = 3, p = 1). \quad (9)$$

The MODERATE profile is the reference benchmark profile, not a universal protocol constant. It targets server-class, desktop, and B2B deployments where approximately 256 MiB of memory per authentication attempt is acceptable. Constrained clients should recalibrate the KSF profile and must not inherit the statement that ML-KEM overhead is practically negligible without remeasurement.

The envelope is sealed using XSalsa20-Poly1305 and a key derived via HKDF; $\text{RegistrationRecord} = \text{Envelope} \parallel PK_C$ (168 bytes of payload and 169 bytes in wire format, including the version prefix).

4.4. Binding of Account Identifier and Context

The protocol fixes additional context that remains implicit in many abstract descriptions of OPAQUE. Every wire-format message carries a one-byte version prefix $v = 0\text{x}01$, which separates the payload from the full

Table 9: KSF profiles and benchmark status

Profile	Parameters	Measured here?	Intended use
LIGHT	$m = 64$ MiB, $t = 2$, $p = 1$	No	Constrained or latency-sensitive clients requiring separate calibration
MODERATE	$m = 256$ MiB, $t = 3$, $p = 1$	Yes	Reference server-class and desktop/B2B profile used for the reported measurements
HARD	$m \geq 512$ MiB, $t \geq 3$, $p = 1$	No	High-value accounts or environments where memory cost is acceptable

transmission format and enables rejection of unsupported versions. The protocol also uses an explicit account identifier **acct**, a stable byte string naming the account, treated not merely as a database lookup key but as cryptographic context.

Define the account-context hash used by the evaluated artifact as a domain-separated binding of the account identifier:

$$\eta = H(L_{\text{ctx}} \parallel \text{acct}). \quad (10)$$

Here **acct** is supplied as a separate API input, is rejected if empty, and is not serialized inside KE1, KE2, or KE3. The version byte v is validated at the wire-format layer rather than mixed into η in the current artifact. A future interoperability profile could make this binding length-prefixed and version-indexed, but that would be a new wire-compatible profile decision rather than a claim about the evaluated implementation. Distinct domain-separation labels separate the baseline OPRF, KSF, and transcript contexts from the added account-binding and hybrid-combiner contexts. The version indices embedded in these labels are local domain identifiers rather than global version numbers of the overall scheme. The identifier **acct** influences the protocol at two points:

1. through derivation of an account-specific OPRF key, as in Eq. (5);
2. through inclusion of η , defined in Eq. (10), in the extended transcript (16), and hence in the hybrid combiner (17) and the derived keys (18).

This binding makes cross-account transplantation visible in transcript verification even when the password is identical, and it makes the role of account identity explicit in the cryptographic specification.

4.5. Authentication Phase and Hybrid Key Exchange

4.5.1. Generation of KE1 from Initiator to Record-Holding Responder

The initiator first samples the OPAQUE authentication randomness and creates the ephemeral ML-KEM key pair advertised in the first message:

$$\begin{aligned} r_{\text{auth}} &\stackrel{\$}{\leftarrow} \mathbb{Z}_q^*, & B_{\text{auth}} &= r_{\text{auth}} \cdot H'(L_{\text{opr}} \parallel 0\text{x}00 \parallel \text{pwd}), \\ e_C &\stackrel{\$}{\leftarrow} \mathbb{Z}_q^*, & E_C &= e_C \cdot g, \\ n_C &\stackrel{\$}{\leftarrow} \{0, 1\}^{192}, & (pk_{\text{kem}}, sk_{\text{kem}}) &\leftarrow \text{ML-KEM-768.KeyGen}(). \end{aligned} \quad (11)$$

The resulting first authentication message is

$$\begin{aligned} \text{KE1} &= B_{\text{auth}} \parallel E_C \parallel n_C \parallel pk_{\text{kem}}, \\ |\text{KE1}| &= 32 + 32 + 24 + 1184 = 1272 \text{ bytes}. \end{aligned} \quad (12)$$

With the one-byte protocol version prefix, the wire message $v \parallel \text{KE1}$ occupies 1273 bytes. The value B_{auth} is a fresh authentication-phase OPRF blinding value and is independent of the registration-phase value B in Eq. (3). In the implementation API and wire parser, this same 32-byte field is named `credential_request`.

4.5.2. Generation of KE2 from Record-Holding Responder to Initiator

Responder ephemeral material:

$$e_S \stackrel{\$}{\leftarrow} \mathbb{Z}_q^*, \quad E_S = e_S \cdot g, \quad n_S \stackrel{\$}{\leftarrow} \{0, 1\}^{192}. \quad (13)$$

Four-way Diffie–Hellman (4DH):

$$dh_1 = sk_S \cdot PK_C, \quad dh_2 = sk_S \cdot E_C, \quad dh_3 = e_S \cdot PK_C, \quad dh_4 = e_S \cdot E_C. \quad (14)$$

ML-KEM-768 encapsulation:

$$(ct_{\text{kem}}, ss_{\text{kem}}) \leftarrow \text{ML-KEM-768.Encaps}(pk_{\text{kem}}). \quad (15)$$

Extended transcript (including post-quantum elements):

$$\begin{aligned}\tau &= E_C \parallel E_S \parallel n_C \parallel n_S \parallel PK_C \parallel PK_S \parallel \text{CredResp} \parallel pk_{\text{kem}} \parallel ct_{\text{kem}} \parallel \eta, \\ \tau_H &= H(L_\tau \parallel \tau).\end{aligned}\tag{16}$$

Hybrid combiner:

$$\begin{aligned}\text{IKM}_{\text{cl}} &= \text{Encode}(dh_1) \parallel \text{Encode}(dh_2) \parallel \text{Encode}(dh_3) \parallel \text{Encode}(dh_4), \\ \text{IKM}_{\text{pq}} &= ss_{\text{kem}}, \\ \text{IKM}_{\text{hyb}} &= \text{IKM}_{\text{cl}} \parallel \text{IKM}_{\text{pq}} \quad (128 + 32 = 160 \text{ bytes}), \\ \text{salt}_\tau &= L_{\text{comb}} \parallel \tau_H, \\ \text{PRK} &= \text{HKDF-Extract}(\text{salt}_\tau, \text{IKM}_{\text{hyb}}).\end{aligned}\tag{17}$$

Figure 4 shows the resulting dataflow from the classical 4DH terms, the ML-KEM shared secret, and the transcript hash into the derived session keys.

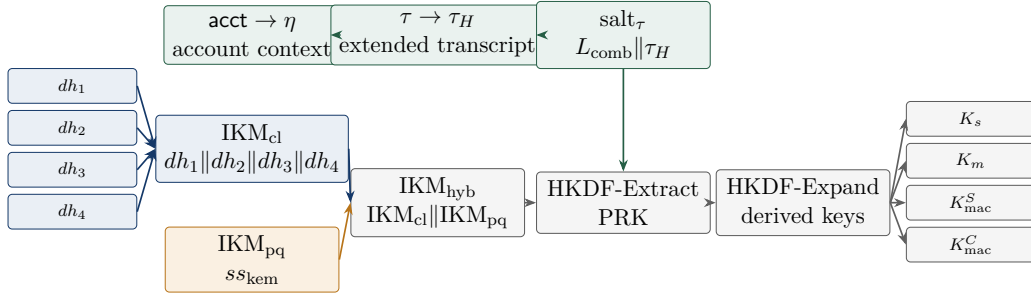


Figure 4: Transcript-bound hybrid key schedule. Classical 4DH material and the ML-KEM shared secret are extracted under a transcript-derived salt before expansion into session, master, and confirmation keys.

Key derivation. Let $\Lambda_s, \Lambda_m, \Lambda_{\text{macS}},$ and Λ_{macC} denote fixed labels for the session key, the master key, and the two confirmation keys:

$$\begin{aligned}K_s &= \text{HKDF-Expand}(\text{PRK}, \Lambda_s, 64), \\ K_m &= \text{HKDF-Expand}(\text{PRK}, \Lambda_m, 32), \\ K_{\text{mac}}^S &= \text{HKDF-Expand}(\text{PRK}, \Lambda_{\text{macS}}, 64), \\ K_{\text{mac}}^C &= \text{HKDF-Expand}(\text{PRK}, \Lambda_{\text{macC}}, 64).\end{aligned}\tag{18}$$

The resulting second authentication message is

$$\begin{aligned}\text{KE2} &= n_S \parallel E_S \parallel \text{CredResp} \parallel \\ &\quad \text{HMAC}(K_{\text{mac}}^S, \tau) \parallel ct_{\text{kem}} \quad (1376 \text{ bytes of payload}).\end{aligned}\tag{19}$$

In wire format, the message is $v \parallel \text{KE2}$ and occupies 1377 bytes.

4.5.3. Generation of KE3 from Initiator to Record-Holding Responder

1. OPRF finalization, opening of the envelope, and recovery of the responder public key, initiator static key, and initiator public key;
2. Mirror 4DH: $dh_1 = sk_C \cdot PK_S$, $dh_2 = e_C \cdot PK_S$, $dh_3 = sk_C \cdot E_S$, $dh_4 = e_C \cdot E_S$ (additional binding of the ephemeral components at the level of 4DH intuition);
3. Decapsulation: $ss_{\text{kem}} = \text{ML-KEM-768.Decaps}(sk_{\text{kem}}, ct_{\text{kem}})$; sk_{kem} is destroyed immediately;
4. Re-derivation of the same PRK; verification of $\text{HMAC}(K_{\text{mac}}^S, \tau)$ by means of a constant-time bitwise comparison without early exit;
5. $\text{KE3} = \text{HMAC}(K_{\text{mac}}^C, \tau)$ (64 bytes of payload, 65 bytes including the version prefix).

4.5.4. Completion at the Record-Holding Responder

KE3 is verified using a constant-time comparison routine. Upon success, the pair (K_s, K_m) becomes available to both parties, thereby confirming mutual authentication. Completion is fail closed: if KE3 is malformed, expired, or fails MAC verification after KE2 has been generated, no session key is exported; responder-held copies of K_s , K_m , ss_{kem} , the expected initiator MAC, and the responder ephemeral secrets are zeroized; and the state becomes terminal or invalidated so the same KE2 state cannot be retried as an authentication oracle.

4.6. Transcript-Binding Check

The transcript definition in Eq. (16) is the normative binding point for the hybrid construction. It requires both pk_{kem} and ct_{kem} to be MAC-authenticated together with the listed classical authentication fields and the account-context hash η . The authentication OPRF blinding value B_{auth} is validated and evaluated in the OPRF path rather than included in τ , and the version byte is handled by the wire-format parser before transcript construction. Any implementation that omits the listed post-quantum fields or η from τ implements a different protocol. The resulting transcript binds the classical and post-quantum key-schedule inputs to a concrete account under the versioned wire format in which the messages are parsed.

5. Security Analysis

5.1. Formal Analysis of Security Properties

Offline guessing under a fixed trust boundary. The relevant compromise case is deliberately narrow. The adversary is allowed to obtain the passive server-side storage rec and the observable transcripts, but not $\sigma_{\text{opr}}f$. Under that condition, the record does not give an efficient offline verifier for dictionary candidates except through a break of OPRF obliviousness or envelope security. If $\sigma_{\text{opr}}f$ is compromised, the problem changes: the attacker can evaluate the account-specific OPRF path and the remaining work is a dictionary search with per-guess cost dominated by Argon2id. The claim is therefore a statement about a specific operational boundary, not about all possible server compromise cases.

Proof sketch. Let S_0, S_1, S_2 denote the real database-disclosure experiment, the experiment with randomized OPRF output, and the experiment with a hidden envelope plaintext, respectively. Let $\mathcal{Q}_{\text{on}}$ be the set of password candidates submitted through online protocol attempts. **Case 1:** $\sigma_{\text{opr}}f$ not compromised. Without the account-specific OPRF key, the adversary cannot compute $y_{\text{opr}}f$ via (6), and hence cannot reconstruct x_{ksf} , salt_{ksf} , or rwd via (9). The envelope record therefore does not provide an effective offline password-checking oracle. Replacing the OPRF output with a random value yields

$$|\Pr[S_1] - \Pr[S_0]| \leq \text{Adv}_{\text{OPRF}}^{\text{obliv}} \leq \text{Adv}_{\text{CDH}}^{\text{Ristretto255}}.$$

Envelope-hiding transition. Next replace the envelope with an encryption of a random string, reducing the change in success probability to the authenticated-encryption security of XSalsa20-Poly1305:

$$|\Pr[S_2] - \Pr[S_1]| \leq \text{Adv}_{\text{XSalsa20-Poly1305}}^{\text{AE}}.$$

Consequence. In the absence of compromise of $\sigma_{\text{opr}}f$, the best available strategy collapses to online guessing, whence

$$\text{Adv}^{\text{dict}} \leq \text{Adv}_{\text{CDH}}^{\text{Ristretto255}} + \text{Adv}_{\text{XSalsa20-Poly1305}}^{\text{AE}} + \Pr[\text{pwd} \in \mathcal{Q}_{\text{on}}].$$

Case 2: $\sigma_{\text{opr}}f$ compromised. Then each dictionary guess pwd' can be checked offline by computing $y'_{\text{opr}}f$, then x'_{ksf} , $\text{salt}'_{\text{ksf}}$, and finally one attempt to open the envelope. The cost of a single guess is dominated, both asymptotically and empirically, by Argon2id, that is, by the procedure (9):

$$T_{\text{guess}} \approx T_{\text{Argon2id}}, \quad C_{\text{offline}} \approx |\mathcal{D}| \cdot T_{\text{guess}}.$$

For a ranked password distribution and a fixed compute budget C_{cpu} , the number of tested candidates is bounded by the lower of the compute and memory bottlenecks:

$$G \leq \min \left(\left\lfloor \frac{C_{\text{cpu}}}{T_{\text{guess}}} \right\rfloor, \left\lfloor \frac{B_{\text{mem}}}{256 \text{ MiB}} \right\rfloor \cdot \left\lfloor \frac{T_{\text{wall}}}{T_{\text{guess}}} \right\rfloor \right),$$

where B_{mem} is the memory available to parallel guesses and T_{wall} is the number of Argon2id time slots in the attack window. This calculation is intentionally operational rather than cryptographic: once σ_{prf} is lost, protection shifts from the aPAKE record property to password entropy, KSF cost, rate controls, and incident response.

Scoped security argument 5.1 (Scoped forward secrecy). Within the compromise model stated above, compromise of the long-term keys sk_C and sk_S after session completion is argued not to suffice to recover K_s , under the hardness of CDH and the IND-CCA security of ML-KEM-768.

Proof sketch. After compromise of both long-term keys, the terms containing a static secret can be reconstructed from the public transcript: $dh_1 = sk_S \cdot PK_C$, $dh_2 = sk_S \cdot E_C$, and $dh_3 = sk_C \cdot E_S$. The remaining classical term $dh_4 = e_S \cdot E_C = e_C \cdot E_S$ still requires recovery of a session ephemeral scalar or a break of CDH on the recorded ephemeral points. In parallel, ss_{kem} remains protected under the IND-CCA security of ML-KEM-768 together with correct erasure and absence of leakage from the session-local sk_{kem} . Thus post-session exposure of long-term keys alone does not reconstruct the full input to the hybrid extractor:

$$\text{Adv}^{\text{FS}} \leq \min \left\{ \text{Adv}_{\text{CDH}}^{\text{Ristretto255}}, \text{Adv}_{\text{ML-KEM}}^{\text{IND-CCA}} \right\} + \text{Adv}_{\text{HKDF}}^{\text{ext}}. \quad (20)$$

Scoped security argument 5.2 (MAC-confirmation argument). Under the PRF model for HMAC-SHA-512, successful confirmation-token forgery after q_{mac} verification attempts is modeled by the estimate

$$\text{Adv}^{\text{mac-conf}} \leq \text{Adv}_{\text{HMAC}}^{\text{PRF}} + q_{\text{mac}}/2^{512}.$$

Interpretive claim on the hybrid-source combiner. Let

$$\begin{aligned} \text{IKM}_{\text{cl}} &= \text{Encode}(dh_1) \parallel \text{Encode}(dh_2) \\ &\quad \parallel \text{Encode}(dh_3) \parallel \text{Encode}(dh_4), \\ \text{IKM}_{\text{pq}} &= ss_{\text{kem}}. \end{aligned}$$

If, for a fixed transcript τ , at least one of the sources IKM_{cl} or IKM_{pq} remains computationally hidden and retains sufficient entropy for the extractor model, then the extracted pre-key is

$$\text{PRK} = \text{HKDF-Extract}(\text{salt}_{\tau}, \text{IKM}_{\text{cl}} \parallel \text{IKM}_{\text{pq}}).$$

This value is treated as pseudorandom under the standard extractor interpretation of HKDF-Extract. This gives the intended hybrid-source reading of the key schedule: explicit recovery of the real session key from the transcript requires compromise of *both* sources. The statement is not a standalone computational proof of the combiner. It is an extractor-based interpretation that is used consistently in the subsequent symbolic model and implementation checks.

Proof sketch. Let S denote the source among $\{\text{IKM}_{\text{cl}}, \text{IKM}_{\text{pq}}\}$ that remains computationally hidden relative to the fixed transcript τ and retains sufficient entropy in the extractor model, and let X denote the other source. Then $\text{IKM}_{\text{cl}} \parallel \text{IKM}_{\text{pq}}$ may be written as $S \parallel X$. The standard extractor property of HMAC-based HKDF-Extract [31] suggests that if S is hidden from the adversary with sufficient entropy, then PRK remains pseudorandom even for arbitrary X . This yields the upper bound: indistinguishability of the final key can fail only through a break of the surviving source or a break of the extractor itself:

$$\text{Adv}^{\text{hybrid}} \leq \min\{\text{Adv}_{\text{CDH}}^{\text{Ristretto255}}, \text{Adv}_{\text{ML-KEM}}^{\text{IND-CCA}}\} + \text{Adv}_{\text{HKDF}}^{\text{ext}}. \quad (21)$$

This bound explains the hybrid-source interpretation used in the sequel. If at least one of the two sources remains computationally hidden, and HKDF-Extract behaves as an extractor, then the derived PRK remains pseudorandom up to the additive extractor term. The interpretation is narrow: in this reduction sketch and in the symbolic analysis below, compromise of the final key is modeled as requiring simultaneous weakening of the classical and post-quantum layers. Figure 5 visualizes this interpretation.

5.2. Resistance to Known Attacks

Offline dictionary attacks. The protection claim is stated for *database compromise without compromise of σ_{oprf}* . Under this condition, three independent layers operate: (1) OPRF, because without the responder-side OPRF key k_{oprf} the adversary cannot compute rwd ; (2) Argon2id with MODERATE parameters (256 MiB, 3 iterations), for which one guess costs approximately $T_{\text{guess}} \approx 0.84$ s on the benchmarking platform, so a sequential

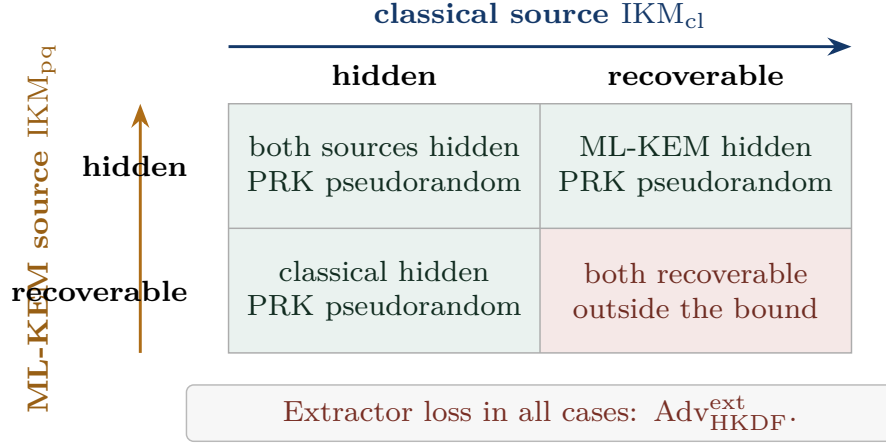


Figure 5: Condition map for the hybrid-combiner interpretation used in Eq. (21). Rows and columns describe whether the classical or ML-KEM source remains hidden relative to a fixed transcript. Under the extractor interpretation, the PRK remains pseudorandom whenever at least one source remains hidden; simultaneous recovery of both sources is the source-level condition not ruled out by the bound, up to the additive extractor term.

exhaustive dictionary search scales as $C_{\text{offline}} \approx |\mathcal{D}| \cdot T_{\text{guess}}$; and (3) XSalsa20-Poly1305, because verification of a candidate requires successful authenticated decryption. If σ_{prf} is compromised, this claim does not automatically transfer to the new threat model and requires separate analysis.

Man-in-the-middle attack. The transcript τ contains the listed public protocol elements, including pk_{kem} and ct_{kem} . Modification of any transcript-bound field results in MAC mismatch; other malformed fields fail during parsing, OPRF or envelope processing, or key confirmation.

Replay attack. Ephemeral nonces (192 bits) and ephemeral keys are generated afresh for every session. For N sessions using uniformly sampled 192-bit nonces, the birthday-bound collision probability is approximately $N(N-1)/2^{193}$.

Harvest-now-decrypt-later attack. If the classical $dh_1, \dots, dh_4$ terms are later recovered by a quantum adversary, the hybrid key still depends on ss_{kem} , whose protection is tied to ML-KEM-768 and the Module-LWE assumption.

Long-term responder-key exposure. Compromise of sk_S permits impersonation of the record-holding responder in future sessions and makes the static-responder DH terms computable from a recorded transcript, including dh_1 and dh_2 . The narrower post-session claim is that sk_S alone does not

reconstruct a completed hybrid session: it does not reveal the initiator static secret, the responder ephemeral scalar, the ephemeral-ephemeral term dh_4 , or the ML-KEM shared secret ss_{kem} , which depends on the destroyed sk_{kem} . The protection statement is therefore scoped to recovery of the recorded hybrid session key, not to impersonation after the responder key has been lost.

Timing and microarchitectural side channels. MAC comparisons are performed by constant-time bitwise comparison without early exit, and secrets are zeroized on both successful and rejected paths. The implementation relies on constant-time-oriented Ristretto255 and ML-KEM components, but the evidence here does not include cache-trace, branch-prediction, power, fault-injection, or compiler-level leakage analysis. Side-channel resistance should therefore be treated as an engineering requirement for a hardened deployment, not as a theorem established by the symbolic models.

5.3. Formal Verification

5.3.1. Verification Overview

The protocol was analyzed with two symbolic tools in the Dolev–Yao model: ProVerif 2.05 and Tamarin Prover 1.10.0. The purpose of this analysis is to check the structure of the protocol argument, not to certify the reference implementation line by line. ProVerif is used in separate secrecy and authentication models, whereas Tamarin is applied to a verified surrogate 4DH model. The results are therefore read together with the modeling boundaries and with the executable artifact that exercises serialization, state handling, and external-call behavior [32, 33].

Tables 10 and 11 separate evidence that is often conflated. ProVerif is most useful for message logic and correspondence properties in a simplified unbounded-session setting; Tamarin records stateful properties under the surrogate 4DH abstraction; and the executable test suite checks concrete state-machine behavior that symbolic tools intentionally abstract away: wire-format parsing, version and length rejection, transcript-field mutation, replay rejection, failure-state consumption, zeroization boundaries, and external-adaptor error contracts. These tests do not replace symbolic analysis; they bind the formalized protocol structure to implementation behavior that callers actually exercise.

Table 10: Symbolic verification summary and modeling boundary

Property	ProVerif	Tamarin	Boundary
Session-key secrecy	confirmed	confirmed in 27 steps	Symbolic secrecy only; no side-channel or compiled-code claim.
Password secrecy on the wire	confirmed	confirmed in 3 steps	Password absence is checked in the model trace abstraction.
Classical forward secrecy	not modeled	confirmed in 119 steps	Uses the surrogate 4DH representation.
Post-quantum contribution	not modeled separately	represented through the hybrid-source lemma	Does not constitute an IND-CCA proof of ML-KEM.
Initiator authentication	confirmed	confirmed in 32 steps	Correspondence assertion under the modeled event structure.
Responder authentication	confirmed	confirmed in 17 steps	Correspondence assertion under the modeled event structure.
Injective mutual authentication	confirmed	follows from authentication lemmas	Not a proof about API misuse or error formatting.
Hybrid-source interpretation	not modeled	supported in 29 steps	Evidence for the stated abstraction, not a computational combiner theorem.
Offline guessing in the DB model	not modeled	supported in 4 steps	Assumes σ_{prf} remains outside the compromised store.
Executability	not applicable	confirmed in 16 steps	Confirms existence of an honest completion trace.
Total	5/5 queries	8/8 lemmas	Results belong to separate symbolic abstractions.

Table 11: Executable artifact checks and what they do not prove

Test area	Representative checks	Does not prove
Wire format and versioning	Exact KE1/KE2/KE3 lengths, unsupported-version rejection, malformed-length rejection	Correctness of every future serialization profile.
Transcript binding	Mutation of transcript-bound fields, including post-quantum material and account context	A general composition theorem for all hybrid PAKEs.
State lifecycle	State consumption, replay rejection, failure-state invalidation, zeroization boundaries	Absence of all memory-forensics or side-channel leakage.
External adapter contract	Public error categories, buffer ownership, safe release paths	Correct integration by arbitrary foreign callers.
Benchmark harnesses	Primitive and protocol workloads under Criterion	Universal timing behavior across platforms.
Total test outcome	157 passed, 1 intentionally ignored slow regression	Machine-checked implementation correctness.

5.3.2. *ProVerif 2.05*

Toolchain: ProVerif 2.05 with OCaml 5.4.0. Two complementary models were used: a baseline secrecy model and a separate authentication model, both archived in the accompanying artifact package. The split into two models is deliberate: a single saturated model did not yield stable convergence for all queries simultaneously. The ProVerif results provide two compatible but distinct views of the same protocol.

Table 12: Split ProVerif models and their abstractions

Model	Queries checked	Principal abstraction
Secrecy model	Session-key secrecy and password secrecy on the wire	Authentication events are simplified so that secrecy saturation converges reliably across unbounded sessions.
Authentication model	Initiator, responder, and injective mutual correspondence	Key-material secrecy is abstracted to focus the model on event ordering and agreement.

The split is acceptable only because both models use the same message roles, transcript fields, compromise events, and success/failure events. It would be misleading to add their outcomes as though they were a single monolithic proof; they are two consistency checks over the same protocol description.

The most informative query for mutual authentication is P5c (injective mutual correspondence): it states that each successful completion on the responder side corresponds to a distinct matching completion on the initiator side for the same pair of parties and the same session key. A positive result

means that successful completion on the responder side cannot be explained by replaying a single successful trace across multiple initiator completions. This result is not a computational proof of the implementation: the model omits side channels, variation in error formatting, timing-related leakage, and a range of network-level details that remain the domain of implementation testing.

5.3.3. Tamarin Prover 1.10.0

Toolchain: Tamarin 1.10.0 (Maude 3.4). A surrogate model of the hybrid combiner was verified; the archived 4DH proof log records a total solving time of **53.84 seconds** for all eight lemmas. Table 13 lists the verified lemmas and their main security interpretation.

Table 13: Tamarin lemmas established for the surrogate 4DH model

Lemma	Steps	Key property
Session-key secrecy (P1)	27	Without corruption events, the adversary cannot derive the session key
Password secrecy (P2)	3	The password never appears in externally observable model events
Forward secrecy (P3)	119	The session key remains non-derivable after post-session long-term key compromise, assuming session ephemerals are not disclosed
Initiator authenticity (P5a)	32	Successful initiator completion requires prior responder participation
Responder authenticity (P5b)	17	Successful responder completion requires a valid KE3
Hybrid-source interpretation (P6)	29	Without compromise of the ephemeral secrets, the 4DH and KEM components are not recovered jointly
Offline-guessing resistance in the DB model (P7)	4	Database compromise reveals the record but not the OPRF key
Executability (correctness)	16	A successful protocol-completion trace exists

The verified Tamarin model does not use an embedded Diffie–Hellman equational theory for the full 4DH construction. Instead, it replaces 4DH with an abstract secret $\xi_{4dh} = h(\langle sk_C, sk_S, e_C, e_S \rangle)$ and checks which compromise events are required for the adversary to derive the session key. This abstraction makes automated reasoning feasible and is interpreted as

surrogate symbolic evidence rather than a formal proof of every concrete Ristretto255 operation. In particular, the model does not test algebraic independence among $dh_1, \dots, dh_4$, canonical point validation, cofactor-related issues, or equality relationships induced by the group law. Those properties are addressed by primitive choice, implementation checks, and the reduction sketches, not by the Tamarin lemma itself.

Lemma P6 is central to the combiner interpretation. It states that from the establishment of the session key and the absence of disclosure of the initiator’s and responder’s ephemeral secrets, non-derivability of that key for the adversary follows. The machine verification of this lemma completes positively in 29 steps.

The lemma permits compromise of long-term keys but disallows disclosure of ephemeral ones. Even with knowledge of the parties’ long-term secrets, the adversary cannot recover the modeled hybrid key material without access to the ephemeral components represented in the classical and post-quantum layers. Within this surrogate model, the result supports the stated hybrid-source interpretation. It does not establish the same claim for a full equational model of Ristretto255 or replace a separate formalization of post-quantum forward secrecy.

5.3.4. *Limits of Interpretation*

To avoid overstating the formal results, four principal limitations are recorded.

1. **Surrogate representation of 4DH.** The verified Tamarin model abstracts the 4DH component into a single knowledge function. This facilitates the proof but does not replace analysis of the concrete algebraic properties of group operations, canonical point decoding, or independence of the four Diffie–Hellman terms.
2. **Split ProVerif models.** Secrecy and authentication are studied not in one universal model but in two separate artifacts. Hence the 5/5 outcome should be interpreted as the aggregate of two mutually consistent models rather than as a monolithic proof.
3. **Boundary of offline-resistance claims.** Lemma P7 and the corresponding executable tests cover database compromise *without* compromise of σ_{prf} . If σ_{prf} is exposed, the offline-resistance property requires separate analysis and should not be transferred automatically from the model.

4. **Gap between model and implementation.** Symbolic verification does not cover side channels, compiler behavior, memory-allocation properties, external-API mistakes, or vulnerabilities in external crates. For this reason, the formal results reported here complement tests and benchmarks rather than substituting for them.

6. Implementation and Experimental Evaluation

6.1. Architecture of the Reference Implementation

The protocol is implemented in **Rust 1.93.1** as a multi-crate workspace. Rust was selected for compile-time memory safety, the ability to keep the cryptographic core free of `unsafe` blocks, and the availability of mature secret-zeroization mechanisms. Table 14 summarizes the implementation surface used for the evaluation.

Table 14: Source-code metrics of the workspace

Component	Role	LoC	Principal dependencies
Cryptographic core	Primitives, key derivation, and protocol serialization	1513	Ristretto255, ML-KEM, Argon2id
Initiator pipeline	Initiator protocol phases	900	cryptographic core
Responder pipeline	Record-holding responder phases and session completion	907	cryptographic core
Interlanguage layer	Foreign-call adapter and protocol invocation	2026	initiator and responder pipelines
Total (main code)		5346	
Tests		4116	property-based and regression scenarios
Benchmarks		1460	Criterion
Formal models		1806	Tamarin, ProVerif

6.2. Specification-to-Implementation Traceability

The implementation is organized so that the main protocol statements in the paper can be checked against concrete artifacts rather than against informal intent. This traceability is not a proof of correctness, but it reduces the risk that the specification, implementation, benchmarks, and adapter documentation drift into describing different protocols. Table 15 summarizes the correspondence used in the artifact.

Table 15: Traceability between the paper specification and executable artifact

Specification element	Implementation locus	Artifact check
Wire-format lengths and version prefix	Core type constants and protocol serialization/parsing routines	Unit tests reject short, long, and unsupported-version messages; public length accessors expose the same 1273/1377/65-byte authentication sizes.
Account-bound OPRF derivation	OPRF and registration/envelope modules shared by the initiator and responder crates	OPRF, envelope, and registration tests cover account-specific derivation, validation failures, and rejection of malformed public inputs.
Hybrid 4DH + ML-KEM key path	Initiator authentication, responder authentication, and ML-KEM helper module	Integration and property-oriented tests exercise successful completion, tampered KE2/KE3 rejection, replay rejection, and independent session-key agreement.
Transcript binding of PQ material and acct	Authentication-state construction on both endpoints	Negative tests mutate transcript-bound fields and require authentication failure rather than silent divergence.
State lifetime and zeroization boundary	Initiator state, responder state, and foreign-call lifecycle wrappers	Regression tests check state consumption, rejection after invalid transitions, and safe release paths across the foreign-call boundary.
Public external error contract	Initiator and responder adapter modules plus the public adapter documentation	Adapter lifecycle tests verify that unsupported protocol versions remain distinguishable at the foreign-call boundary instead of being collapsed into generic authentication failure.

The important point is methodological. The symbolic models describe the message structure and compromise assumptions; the executable tests check whether the executable state machine follows the same message sizes, labels, version handling, and rejection behavior; and the adapter documentation exposes the subset of those contracts that external callers must obey. This separation makes the artifact more directly auditable because cryptographic claims, implementation invariants, and foreign-call obligations are related but not treated as interchangeable evidence.

6.3. Memory Safety and Secret Zeroization

For a cryptographic system, security depends not only on the selected primitives but also on the discipline with which secrets are handled in process memory. In the implementation studied here, the cryptographic core and both protocol pipelines are compiled under a strict `no-unsafe-code` policy, whereas operations that require low-level pointer manipulation are confined to a narrow foreign-call boundary. Such architectural separation does not replace formal analysis of the implementation, but it limits the defect surface at the memory-management boundary: use-after-free defects, double release, loss of correct buffer ownership, and violations of buffer-length invariants.

Control over secret lifetime is equally important. The implementation systematically applies automatic zeroization when objects leave scope together with dedicated wrappers for transient values, so that sensitive intermediate quantities remain in memory only for the minimal interval required. This does not eliminate every possible leak, but it reduces the post-compromise residue of sensitive data in memory dumps, crash logs, and reused buffers. In particular, the following values are zeroized:

- the user password and the OPRF blinding scalar after OPRF finalization;
- the ephemeral ML-KEM secret after decapsulation;
- the classical 4DH material, the transcript hash, and the PRK after derivation of descendant keys;
- the account-and-version context hash η after completion of KE2/KE3;
- the initiator and responder state structures upon interruption or any rejected completion path.

6.4. Testing and Reproducibility

The evaluated revision of the workspace contains 157 passing tests and 1 deliberately ignored slow regression scenario. The package includes unit, integration, property-based, and regression tests for the protocol lifecycle, wire format, external API contract, OPRF/KEM correctness, and secure rejection of invalid states.

For archival review, the source snapshot should record the exact commit identifier and the commands used to reproduce each evidence layer: `cargo`

`test -workspace` for executable tests, the documented Criterion benchmark targets for timing, `proverif` for the two ProVerif files, and `tamarin-prover` for the archived Tamarin model. The expected review outcome for the snapshot described here is 157 passed tests, one intentionally ignored slow regression, 5/5 ProVerif queries, and 8/8 Tamarin lemmas.

These checks complement the symbolic analysis rather than duplicate it. Executable tests exercise serialization, version handling, state-lifecycle invariants, and input-boundary conditions in the executable implementation; Criterion 0.5.1 benchmarks [34] quantify the cost of the main primitives and protocol phases; archived ProVerif and Tamarin models document the formal abstractions used for the security claims.

Benchmarking was performed on a Linux server with two Intel Xeon E5-2650 v4 processors (24 physical cores, 48 hardware threads, 60 MiB aggregate L3 cache, Ubuntu kernel 6.8.0-111, Rust 1.93.1) in deterministic optimized-build mode. Criterion applies bootstrap estimation of the mean and the 95% confidence interval; the values reported below should be interpreted as reproducible estimates for this platform rather than as universal constants for every environment. Reproducing the full test suite, the benchmark suite, and the formal models gives an independent check on the main quantitative and structural claims reported here.

6.5. Benchmarks of Cryptographic Primitives

Figure 6 summarizes the scale separation before the detailed benchmark tables.

Table 16 gives the primitive-level measurements behind this profile.

The micro-benchmarks show three stable relationships. First, the full ML-KEM-768 round (492.30 μ s) and the measured 4DH protocol profile (245.57 μ s) remain sub-millisecond operations, so the post-quantum layer does not alter the computational class of the protocol. Second, Argon2id (841.37 ms in isolated measurement) dominates all other components and determines the perceived authentication latency. Third, the hybrid key-extraction procedure (2.49 μ s) is negligible relative to the KSF and does not constitute a separate bottleneck.

6.6. Protocol-Level Benchmarks

The phase measurements and the complete authentication measurement are separate Criterion workloads with different state-initialization and batching boundaries. They are therefore not additive. Table 17 reports scenario-

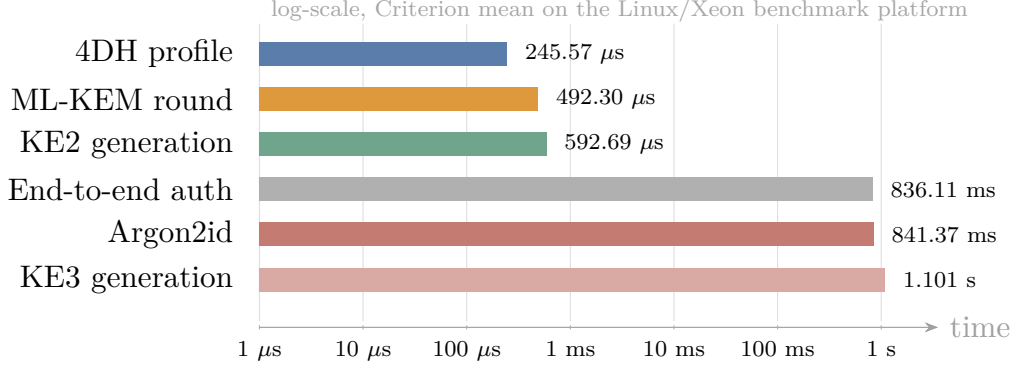


Figure 6: Runtime profile on the Linux/Xeon benchmark platform. The password-hardening step dominates end-to-end latency, while the post-quantum and classical key-exchange components remain sub-millisecond.

Table 16: Benchmark results for cryptographic primitives

Primitive	Operation	$\hat{\mu}$	95% CI
Ristretto255	Key-pair generation	41.85 μ s	[39.47; 44.28]
Ristretto255	Single DH	75.93 μ s	[74.11; 77.90]
Ristretto255	3DH (baseline)	262.54 μ s	[258.50; 266.58]
Ristretto255	4DH (protocol profile)	245.57 μs	[242.98; 249.55]
ML-KEM-768	Key-pair generation	151.48 μ s	[147.39; 155.63]
ML-KEM-768	Encapsulation	146.50 μ s	[142.58; 150.51]
ML-KEM-768	Decapsulation	172.74 μ s	[168.74; 176.75]
ML-KEM-768	Full round	492.30 μs	[479.59; 505.34]
OPRF	Blinding	115.63 μ s	[113.63; 117.64]
OPRF	Responder evaluation	76.39 μ s	[74.95; 77.85]
OPRF	Finalization	109.11 μ s	[107.29; 110.91]
HKDF	Extract	3.63 μ s	[3.52; 3.74]
HKDF	Expand (64 bytes)	2.26 μ s	[2.20; 2.33]
HMAC-SHA-512	256 bytes	2.92 μ s	[2.90; 2.94]
XSalsa20-Poly1305	Encrypt 96 bytes	2.52 μ s	[2.49; 2.57]
XSalsa20-Poly1305	Decrypt 96 bytes	2.67 μ s	[2.66; 2.69]
Argon2id	MODERATE	841.37 ms	[830.54; 851.96]
Hybrid combiner	HKDF-Extract (160 bytes)	2.49 μ s	[2.47; 2.50]

level timings rather than a decomposition whose rows sum to the end-to-end value.

Table 17: Benchmark results for protocol-level scenarios; rows are separate Criterion workloads and are not additive

Phase	Measurement scenario	$\hat{\mu}$	95% CI	Main cost
Registration	Registration-request creation	127.37 μ s	[125.24; 130.09]	OPRF blinding
Registration	Responder response creation	71.42 μ s	[70.98; 71.84]	OPRF evaluation
Registration	Registration completion	1.065 s	[993.93 ms; 1.143 s]	Argon2id
Authentication	KE1 generation	304.87 μ s	[288.05; 322.18]	OPRF + ML-KEM keygen
Authentication	KE2 generation	592.69 μ s	[582.16; 606.72]	4DH + ML-KEM encaps.
Authentication	KE3 generation at the initiator	1.101 s	[1.034; 1.169] s	Argon2id + decapsulation
Authentication	Final responder verification	2.61 μ s	[2.31; 3.06]	MAC verification
Full	End-to-end authentication cycle	836.11 ms	[825.41; 847.99]	Argon2id

Responder KE2 generation remains a sub-millisecond operation, whereas Argon2id contributes the overwhelming share of time.

6.7. Key Quantitative Findings and Implementation Implications

The isolated responder profile shows that the responder’s cryptographic core remains compatible with high-throughput deployment: isolated KE2 generation takes 592.69 μ s, whereas final responder verification takes only 2.61 μ s. This yields a theoretical upper bound of approximately 1.69×10^3 authentications per second per core for a cryptography-bound responder, excluding database access, telemetry, and business logic.

For the complete AKE without the KSF, the post-quantum component adds 379.45 μ s (+48.3%) of CPU time; against the Argon2id background, however, this excess shrinks to approximately 0.045% of a typical end-to-end scenario. The principal trade-off is not CPU cost but network volume: the complete handshake occupies 2715 bytes in wire format, that is, 2272 bytes more than the classical variant at the same three-message interaction profile.

Comparative claim relative to classical OPAQUE. Let $M_{\text{opq}}, R_{\text{opq}}, C_{\text{opq}}, W_{\text{opq}}$ denote, respectively, the message count, network round-trip cost, cryptographic computation, and communication volume of canonical 3DH-OPAQUE without the KSF, and let $M_{\text{hyb}}, R_{\text{hyb}}, C_{\text{hyb}}, W_{\text{hyb}}$ denote the corresponding quantities for Hybrid PQ-OPAQUE. Let C_{misc} collect the

fixed transcript-binding, serialization, and key-derivation work introduced by the hybrid path. Then

$$\begin{aligned} M_{\text{hyb}} &= M_{\text{opq}} = 3, \\ R_{\text{hyb}} &= R_{\text{opq}} = \frac{3}{2} \text{ RTT}, \\ C_{\text{hyb}} &= C_{\text{opq}} + C_{\text{DH}} + C_{\text{KEM}} + C_{\text{misc}}, \\ W_{\text{hyb}} &= W_{\text{opq}} + \Delta W, \quad \Delta W = 2272 \text{ bytes}. \end{aligned}$$

On the benchmark platform, this corresponds to a measured increase of $C_{\text{DH}} + C_{\text{KEM}} + C_{\text{misc}} \approx 379.45 \mu\text{s}$ without the KSF. Compared with the established baseline of classical OPAQUE, the cost for honest parties rises additively, and the interaction profile is unchanged. Within the present threat model, explicit compromise of the final key material is not reducible to weakening the classical contribution alone; it is interpreted as requiring compromise of both the classical and post-quantum layers. Table 18 states the same comparison in structural form.

Table 18: Comparison of Hybrid PQ-OPAQUE with canonical 3DH-OPAQUE

Aspect	3DH-OPAQUE	Hybrid PQ-OPAQUE	Interpretation
Interaction profile	3 messages, 1.5 RTTs	3 messages, 1.5 RTTs	Protocol interaction is unchanged
Computational complexity for honest parties	Baseline 3DH path	+1 additional DH, + KEM, + fixed transcript/KDF work	The increase is additive rather than structural
Communication complexity	Baseline handshake volume	+2272 bytes in wire format	The principal practical trade-off shifts to transport
Key-compromise condition	Weakening of the classical contribution	Compromise of both the classical and PQ layers	The recovery condition is stricter within the present threat model

7. Discussion of Results

7.1. Interpretation of the Formal and Experimental Evidence

The evidence should be read as layered rather than monolithic. ProVerif addresses secrecy and correspondence in symbolic models, Tamarin records stateful properties of the surrogate 4DH construction, and the Rust test suite checks executable behavior that symbolic tools do not model: serialization, state lifetime, boundary checks, version handling, and the external API contract. These layers point to the same protocol description, but they do not have the same evidentiary status.

The least automatic part of the argument is the hybrid-source reading of the combiner. It is supported by the extractor rationale and by the surrogate Tamarin lemma, but it is still weaker than a full computational proof. This distinction is important because the paper is not claiming that the implementation is machine-verified; it claims that the design, models, tests, and measurements are mutually consistent under the stated assumptions. Table 19 separates these claims from their boundaries.

Table 19: Scope of the main claims and supporting evidence

Claim	Evidence used in the paper	Boundary of the claim
Fixed-round hybridization	Explicit message syntax, transcript definitions, wire-format accounting, and Rust serialization tests	The construction is OPAQUE-like and does not claim complete RFC 9807 conformance.
Transcript-bound post-quantum contribution	Key-schedule equations, context binding through <code>acct</code> , formal models, and integration tests	The formal tools reason about symbolic abstractions, not the compiled binary or side-channel behavior.
Resistance to database-only offline guessing	OPRF-key separation, database-compromise model, negative regression tests, and the stated trust boundary for σ_{oprf}	The claim does not survive compromise of the OPRF root secret or a deployment that stores it with the password database.
Hybrid-source key dependence	HKDF extractor rationale, the surrogate 4DH Tamarin lemma, and agreement between the specification and implementation paths	This is evidence for the intended combiner interpretation, not a full computational proof of the hybrid PAKE.
Practical overhead is dominated by the KSF	Criterion measurements for primitive costs, end-to-end authentication, and message-size accounting	The absolute timings are platform-specific and must be recalibrated for mobile, embedded, or high-latency deployments.

7.2. Performance, KSF Parameters, and the Trust Boundary

The performance profile is governed mainly by Argon2id; ML-KEM-768 and 4DH remain sub-millisecond components. The relevant deployment constraint is therefore not the absolute cost of ML-KEM-768, but the choice of KSF profile for the target initiator population. The selected profile is appropriate for web and B2B settings, whereas mobile and edge deployments may require separate KSF calibration and stricter rate limiting.

The trust boundary around σ_{oprf} is not a cosmetic detail. Resistance to offline guessing is claimed only for database compromise *without* compromise of that secret. In operational terms, σ_{oprf} functions as the root cryptographic secret of the service and requires separated storage, segregated access, minimal memory residency, and a rotation policy that treats OPRF-key derivation as privileged cryptographic state.

A practical advantage of the migration path is that the post-quantum component remains ephemeral and does not enlarge the registration record. Migration is concentrated in the application-layer authentication logic, version negotiation, and contextual binding of `acct`. The growth of the wire format to 2715 bytes, however, makes transport constraints more consequential than in classical OPAQUE: for TCP/QUIC this is largely a buffering issue, whereas datagram deployments also face fragmentation and MTU concerns.

7.3. Migration, Compatibility, and Operational Viability

The construction can be deployed without redesign of the entire identity stack for two reasons. First, the registration record does not accumulate long-lived post-quantum material, because ML-KEM appears only in the ephemeral authentication path. Second, explicit wire-format versioning and contextual binding of `acct` permit staged rollout without invalidating existing user state. For operators, migration is therefore closer to controlled protocol evolution than to complete credential re-issuance.

Operational compatibility also matters. Authentication interacts with login-attempt limits, logging, account recovery, anti-fraud analysis, and audit requirements. The implementation therefore emphasizes deterministic serialization, explicit version checking, and stable external-call boundaries. Failure modes should also remain distinguishable: cryptographic failure, version-negotiation failure, and transport failure have different operational meanings, and collapsing them into a generic failed login would obscure diagnosis during deployment. The same distinction between cryptographic, transport, and workflow failures matters in audit-heavy cyber-physical deployments, where authentication is part of a broader telemetry and inspection pipeline rather than an isolated login step, as noted in the application motivation in Section 1.

7.4. Reproducibility and Artifact Transparency

The artifact is useful because it forces the specification to meet the implementation boundary. The same wire sizes, transcript fields, key schedule, and error paths appear in the paper, the Rust crates, and the adapter documentation. This makes it possible to compare the written protocol against executable behavior rather than treating the paper and the implementation as separate claims.

This linkage also keeps the interpretation of the evidence disciplined. The hybrid-source argument belongs to the Tamarin abstraction and the

combiner rationale. Parsing correctness, rejection of non-canonical points, version handling, and prevention of state reuse are properties of the reference implementation and its tests. For post-quantum migration work, that separation is useful: it makes the strengths of the artifact visible without hiding the parts that still require stronger analysis.

7.5. *Validity, Limitations, and Future Directions*

The work has several material limitations. The implementation is OPAQUE-like rather than fully conformant to RFC 9807 and the associated standard interfaces [5]. The symbolic models do not replace a computational proof of the implementation code, and the benchmark measurements were obtained on a single hardware platform; consequently, absolute microsecond-level values should be transferred to other architectures with caution. Finally, ML-KEM-768 is a relatively recent standard, so hybridization reduces dependence on a single assumption but does not remove the need for continued cryptanalysis of the post-quantum layer.

Further development of the work is most naturally directed along four lines:

1. adaptation to RFC 9807 and the associated OPAQUE/OPRF ecosystem;
2. formalization of the hybrid extension in a computational or UC setting [25];
3. investigation of alternative KSF profiles and ML-KEM variants for mobile and IoT scenarios;
4. integration of external post-quantum signatures for settings in which non-repudiation is required, without altering the baseline HMAC-based handshake confirmation.

8. Conclusion

Numerical result. The study specifies an OPAQUE-derived hybrid authentication profile that keeps the KE1–KE2–KE3 interaction pattern unchanged while adding ML-KEM-768 to the authenticated transcript. The complete hybrid handshake occupies 2715 bytes in wire format, which is a 2272-byte expansion over the classical payload. On the stated Linux/Xeon platform, the complete authentication workload takes 836.11 ms, the isolated ML-KEM-768 round takes 492.30 μ s, the 4DH protocol profile takes

245.57 μ s, and the KSF-free post-quantum path adds 379.45 μ s. These numbers make the main cost profile clear: Argon2id dominates latency, while ML-KEM mainly changes the transport budget.

Validated boundary. The evidence supports a bounded design argument rather than a universal security claim. ProVerif confirms the modeled secrecy and authentication queries in two separate models; Tamarin establishes 8/8 lemmas in a surrogate 4DH model; and the reference implementation exercises the wire format, state machine, rejection behavior, tests, and benchmark paths. The limitations are equally important: the implementation is not a full RFC 9807 instantiation, the Tamarin model abstracts the concrete Ristretto255 algebra, the ProVerif strategy is split across two files, the benchmark uses one hardware platform, and dictionary resistance is claimed only for database compromise without compromise of $\sigma_{\text{opr}}f$.

Next work. The natural next step is a conformance-oriented profile aligned more tightly with RFC 9807 and the CFRG OPRF ecosystem, followed by a computational combiner proof or a UC treatment of the hybrid extension. Broader hardware measurements are needed for mobile, browser, and embedded deployments, and a hardened deployment profile should add side-channel evaluation, operational handling of $\sigma_{\text{opr}}f$, and a migration plan for environments that require post-quantum signatures.

Data and Software Availability

The implementation, tests, benchmarks, and formal models are maintained in the accompanying source repository: <https://github.com/oleksandrmelnnychenko/aura-security-opaque-rs>. The submission artifact should identify the exact revision used for review and, where required by the venue, include the same revision as a source bundle or DOI-backed archive. The snapshot contains the Rust protocol crates, foreign-call adapter, deterministic and property-oriented tests, Criterion benchmark harnesses, ProVerif models, Tamarin model, and archived verification logs. For the artifact state described here, the reproducibility target is 157 passed tests, one intentionally ignored slow regression, 5/5 ProVerif queries, and 8/8 Tamarin lemmas.

Funding

The author declares that this research received no external funding.

CRedit Author Statement

Oleksandr Melnychenko: conceptualization, methodology, software, validation, formal analysis, investigation, writing—original draft, writing—review and editing, and visualization.

Declaration of Competing Interest

The author declares that there are no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgments

The author acknowledges OpenAI Codex for the limited manuscript-editing assistance described in the dedicated declaration below.

Declaration of Generative AI and AI-assisted technologies in the writing process

OpenAI Codex was used during manuscript preparation to assist with English-language editing, consistency checks, and minor $\text{\LaTeX}$ typesetting support in portions of the abstract, introduction, discussion, conclusion, and connective prose. OpenAI Codex was not used as an authoritative source for technical claims, references, equations, implementation results, or experimental measurements. All protocol descriptions, equations, references, tables, implementation details, and experimental results were independently reviewed, verified, and approved by the author, who takes full responsibility for the content of the article.

References

- [1] Bonneau J., Herley C., van Oorschot P.C., Stajano F. The quest to replace passwords: a framework for comparative evaluation of web authentication schemes. In: Proceedings of the IEEE Symposium on Security and Privacy, 2012, pp. 553–567. DOI: <https://doi.org/10.1109/SP.2012.44>.

- [2] Florencio D., Herley C. A large-scale study of web password habits. In: Proceedings of the International Conference on World Wide Web, 2007, pp. 657–666. URL: <https://archives.iw3c2.org/www2007/papers/paper620.pdf>.
- [3] Bellare M., Pointcheval D., Rogaway P. Authenticated key exchange secure against dictionary attacks. In: EUROCRYPT 2000, LNCS 1807, Springer, 2000, pp. 139–155. DOI: https://doi.org/10.1007/3-540-45539-6_11.
- [4] Jarecki S., Krawczyk H., Xu J. OPAQUE: an asymmetric PAKE protocol secure against pre-computation attacks. In: EUROCRYPT 2018, LNCS 10822, Springer, 2018, pp. 456–486. DOI: https://doi.org/10.1007/978-3-319-78372-7_15.
- [5] Bourdrez D., Krawczyk H., Lewi K., Wood C.A. The OPAQUE Augmented Password-Authenticated Key Exchange (aPAKE) Protocol. IRTF RFC 9807, July 2025. URL: <https://www.rfc-editor.org/info/rfc9807>.
- [6] Shor P.W. Algorithms for quantum computation: discrete logarithms and factoring. In: Proceedings of the IEEE Symposium on Foundations of Computer Science, 1994, pp. 124–134. DOI: <https://doi.org/10.1109/SFCS.1994.365700>.
- [7] Bernstein D. J., Lange T. Post-quantum cryptography. Nature 549(7671) (2017) 188–194. DOI: <https://doi.org/10.1038/nature23461>.
- [8] Roetteler M., Naehrig M., Svore K.M., Lauter K. Quantum resource estimates for computing elliptic curve discrete logarithms. In: ASIACRYPT 2017, LNCS 10625, Springer, 2017, pp. 241–270. DOI: https://doi.org/10.1007/978-3-319-70697-9_9.
- [9] Babbush R., Zalcman A., Gidney C., Broughton M., Khattar T., Neven H., Bergamaschi T., Drake J., Boneh D. Securing elliptic curve cryptocurrencies against quantum vulnerabilities: resource estimates and mitigations. Google Quantum AI whitepaper, March 30, 2026. URL: <https://quantumai.google/static/site-assets/downloads/cryptocurrency-whitepaper.pdf>.

- [10] Mosca M. Cybersecurity in an era with quantum computers: will we be ready? *IEEE Security & Privacy* 16(5) (2018) 38–41. DOI: <https://doi.org/10.1109/MSP.2018.3761723>.
- [11] National Institute of Standards and Technology. Module-Lattice-Based Key-Encapsulation Mechanism Standard: FIPS 203. 2024. URL: <https://csrc.nist.gov/pubs/fips/203/final>.
- [12] National Institute of Standards and Technology. Module-Lattice-Based Digital Signature Standard: FIPS 204. 2024. URL: <https://csrc.nist.gov/pubs/fips/204/final>.
- [13] Stebila D., Fluhrer S., Gueron S. Hybrid key exchange in TLS 1.3. IETF Internet-Draft draft-ietf-tls-hybrid-design-16, work in progress, September 2025. URL: <https://datatracker.ietf.org/doc/draft-ietf-tls-hybrid-design/>.
- [14] Brendel J., Fischlin M., Günther F., Janson C., Stebila D. Towards post-quantum security for Signal’s X3DH handshake. In: *SAC 2020*, LNCS 12804, Springer, 2020, pp. 404–430. DOI: https://doi.org/10.1007/978-3-030-81652-0_16.
- [15] Hülsing A., Ning K.-C., Schwabe P., Weber F., Zimmermann P. R. Post-quantum WireGuard. In: *Proceedings of the IEEE Symposium on Security and Privacy*, 2021, pp. 304–321. DOI: <https://doi.org/10.1109/SP40001.2021.00030>.
- [16] Arriaga A., Barbosa M., Jarecki S., Skrobot M. C’est très CHIC: a compact password-authenticated key exchange from lattice-based KEM. *Cryptology ePrint Archive*, Paper 2024/308, 2024. URL: <https://eprint.iacr.org/2024/308>.
- [17] Lyu Y., Liu S., Han S. Universal composable password authenticated key exchange for the post-quantum world. In: *EUROCRYPT 2024*, LNCS 14657, Springer, 2024, pp. 120–150. DOI: https://doi.org/10.1007/978-3-031-58754-2_5.
- [18] Hesse J., Rosenberg M. PAKE combinators and efficient post-quantum instantiations. *Cryptology ePrint Archive*, Paper 2024/1621, 2024. URL: <https://eprint.iacr.org/2024/1621>.

- [19] Lyu Y., Liu S. Hybrid password authentication key exchange in the UC framework. Cryptology ePrint Archive, Paper 2024/1630, 2024. URL: <https://eprint.iacr.org/2024/1630>.
- [20] Boyko V., MacKenzie P., Patel S. Provably secure password-authenticated key exchange using Diffie–Hellman. In: EUROCRYPT 2000, LNCS 1807, Springer, 2000, pp. 156–171. DOI: https://doi.org/10.1007/3-540-45539-6_12.
- [21] Bellare S.M., Merritt M. Encrypted key exchange: password-based protocols secure against dictionary attacks. In: Proceedings of the IEEE Symposium on Security and Privacy, 1992, pp. 72–84. DOI: <https://doi.org/10.1109/RISP.1992.213269>.
- [22] Ladd W. SPAKE2, a password-authenticated key exchange. IRTF RFC 9382, September 2023. URL: <https://www.rfc-editor.org/info/rfc9382>.
- [23] Haase B., Labrique B. AuCPace: efficient verifier-based PAKE protocol tailored for the IIoT. IACR Transactions on Cryptographic Hardware and Embedded Systems 2019(2) (2019) 1–48. DOI: <https://doi.org/10.46586/tches.v2019.i2.1-48>.
- [24] Wu T. The Secure Remote Password protocol. In: Proceedings of NDSS, 1998, pp. 97–111. URL: <https://www.ndss-symposium.org/ndss1998/secure-remote-password-protocol/>.
- [25] Canetti R. Universally composable security: a new paradigm for cryptographic protocols. In: Proceedings of the IEEE Symposium on Foundations of Computer Science, 2001, pp. 136–145. DOI: <https://doi.org/10.1109/SFCS.2001.959888>.
- [26] de Valence H., Grigg J., Hamburg M., Lovecruft I., Tankersley G., Val-sorda F. The ristretto255 and decaf448 groups. IRTF RFC 9496, December 2023. URL: <https://www.rfc-editor.org/info/rfc9496>.
- [27] Esgin M.F., Steinfeld R., Tairi E., Xu J. LeOPaRd: towards practical post-quantum oblivious PRFs via interactive lattice problems. Cryptology ePrint Archive, Paper 2024/1615, 2024. URL: <https://eprint.iacr.org/2024/1615>.

- [28] Castryck W., Decru T. An efficient key recovery attack on SIDH. In: EUROCRYPT 2023, LNCS 14008, Springer, 2023, pp. 423–447. DOI: https://doi.org/10.1007/978-3-031-30589-4_15.
- [29] Vos J., Jarecki S., Wood C.A. Hybrid Post-Quantum Password Authenticated Key Exchange. Individual Internet-Draft draft-vos-cfrg-pqpake-00, April 2025. URL: <https://datatracker.ietf.org/doc/draft-vos-cfrg-pqpake/00/>.
- [30] Biryukov A., Dinu D., Khovratovich D. Argon2: new generation of memory-hard functions for password hashing. In: Proceedings of IEEE European Symposium on Security and Privacy, 2016, pp. 292–302. DOI: <https://doi.org/10.1109/EuroSP.2016.31>.
- [31] Krawczyk H., Eronen P. HMAC-based Extract-and-Expand Key Derivation Function (HKDF). IETF RFC 5869, 2010. URL: <https://www.rfc-editor.org/info/rfc5869>.
- [32] Cremers C., Mauw S. Operational Semantics and Verification of Security Protocols. Springer, 2012. DOI: <https://doi.org/10.1007/978-3-540-78636-8>.
- [33] Basin D., Cremers C., Meadows C. Model checking security protocols. In: Handbook of Model Checking. Springer, 2018, pp. 727–762. DOI: https://doi.org/10.1007/978-3-319-10575-8_22.
- [34] Heisler B. Criterion.rs: statistics-driven micro-benchmarking in Rust. Project site. URL: <https://github.com/bheisler/criterion.rs>.
- [35] Svystun S., Scisło L., Pawlik M., Melnychenko O., Radiuk P., Savenko O., Sachenko A. DyTAM: accelerating wind turbine inspections with dynamic UAV trajectory adaptation. Energies 18(7) (2025) 1823. URL: <https://ouci.dntb.gov.ua/en/works/7pXNBeoR/>.
- [36] Svystun S., Melnychenko O., Radiuk P., Savenko O., Sachenko A., Lysyi A. Thermal and RGB images work better together in wind turbine damage detection. International Journal of Computing 23(4) (2024) 526–535. DOI: <https://doi.org/10.47839/ijc.23.4.3752>.
- [37] Lysyi A., Sachenko A., Radiuk P., Lysyi M., Melnychenko O., Ishchuk O., Savenko O. Enhanced fire hazard detection in solar

power plants: an integrated UAV, AI, and SCADA-based approach. *Radioelectronic and Computer Systems* (2) (2025) 99–117.
URL: <https://openurl.ebsco.com/contentitem/doi%3A10.32620%2Freks.2025.2.06?id=ebsco%3Adoi%3A10.32620%2Freks.2025.2.06&sid=ebsco%3Aplink%3Acrawler>.